

AI Risk Tiering Decision Tree

Company: [COMPANY NAME]

Tiering owner: [AI GOVERNANCE LEAD]

Date:

Related record: AI Risk Intake and Impact Assessment

How to use. Use this decision tree before approving a new AI tool, workflow, or material change. Answer the questions in order. Stop at the first tier that applies. If you are unsure between tiers, choose the higher tier and document why.

Tier labels

Tier	Plain-English meaning	Typical review path
Tier 1 - Low	Internal productivity or public-data use with limited downside	Inventory entry, approved-tool rules, annual spot check
Tier 2 - Medium	Customer-facing, confidential, external, or operationally meaningful use	Inventory entry, light impact assessment, human review, annual review
Tier 3 - High	Consequential decisions, sensitive data, biometric/synthetic media, regulated sectors, or material harm potential	Full impact assessment, qualified review, documented controls, leadership approval, shorter review cycle
Tier 4 - Prohibited / pause	Use appears prohibited, deceptive, unlawful, or outside risk appetite	Do not deploy; escalate for qualified review

Start here

Question 1 - Is the use prohibited or clearly outside policy?

Pause if the proposed use involves any of the following:

- Social scoring of people
- Deceptive impersonation or undisclosed synthetic media where disclosure is required
- Emotion recognition in workplace or education contexts without a narrow approved basis
- Biometric categorization or identification that may violate applicable law
- Manipulation, exploitation, harassment, discrimination, or unlawful content
- Pasting credentials, secrets, private keys, or restricted data into an unapproved AI tool
- Any use your organization has already prohibited

If yes or possibly yes: Tier 4 - do not deploy until qualified review clears the use.

If no: continue to Question 2.

Question 2 - Does the use affect important decisions about people?

Does the AI system make, recommend, rank, score, screen, or materially inform a decision about a person in any of these areas?

- Hiring, promotion, termination, compensation, or work assignment
- Credit, lending, pricing, insurance, benefits, or eligibility
- Housing, education, healthcare, legal services, government services, or essential services
- Safety, security, discipline, access, or rights-affecting decisions

If yes: Tier 3 - complete the full AI Risk Intake and Impact Assessment and route for qualified review.

If no or unclear: continue to Question 3.

Question 3 - Does the use involve sensitive data or regulated records?

Will the tool process or infer any of the following?

- Customer, employee, student, patient, applicant, or user personal data
- Health, financial, biometric, children's, government ID, legal, or regulated data
- Confidential business records, trade secrets, source code, or contract-restricted data
- Data received under an NDA or customer contract

If sensitive or regulated data is central to the use: Tier 3 unless a qualified reviewer documents a lower tier.

If confidential business data is involved but not regulated: Tier 2 minimum.

If only public or approved non-sensitive data is involved: continue to Question 4.

Question 4 - Will output be customer-facing, public, or high visibility?

Examples include customer support replies, sales outreach, marketing claims, public blog posts, website copy, product documentation, chatbot output, or generated images/audio/video.

If yes: Tier 2 minimum. Use human review before external use.

If the output could materially mislead, affect rights, or create legal/regulatory exposure: Tier 3.

If no: continue to Question 5.

Question 5 - Can the tool act on its own or connect to business systems?

Will the tool connect to email, CRM, files, code repositories, databases, payment systems, production systems, calendars, ticketing systems, or other internal tools?

Can it send messages, change records, create tickets, execute code, make purchases, approve requests, or trigger workflows?

If yes, autonomous or production-impacting: Tier 3 unless tightly bounded and approved.

If yes, read-only or low-impact integration: Tier 2 minimum.

If no: continue to Question 6.

Question 6 - Could a failure cause material harm?

Consider whether incorrect, biased, leaked, or manipulated output could cause:

- Meaningful harm to a person
- Customer loss, complaint, or reputational damage
- Financial loss above [THRESHOLD]
- Security incident or privacy incident
- Contract breach or regulatory notification
- Publication of false, misleading, infringing, or unsafe content

If material harm is plausible: Tier 2 or Tier 3 depending on severity.

If only routine rework or inconvenience is plausible: Tier 1 may be appropriate.

Tier summary and required actions

Tier 1 - Low

Examples:

- Brainstorming internal ideas
- Summarizing public documents
- Drafting non-sensitive internal text
- Learning how to use a software feature

Required actions:

- ☐ Use only approved tools
- ☐ Add recurring use to the AI Use Inventory
- ☐ Follow Green / Yellow / Red AI Use Rules
- ☐ Review output before using it
- ☐ Reassess if data, audience, or workflow changes

Tier 2 - Medium

Examples:

- Customer-facing content with human review
- Confidential internal analysis
- Code assistance without secrets or restricted code
- Meeting summaries with approved data controls
- Read-only integrations with internal systems

Required actions:

- ☐ Complete relevant sections of the AI Risk Intake and Impact Assessment
- ☐ Name a business owner
- ☐ Define approved data categories and prohibited data
- ☐ Define human review before external or important use
- ☐ Add conditions and next review date to the AI Use Inventory
- ☐ Log material changes in the AI Update Tracker

Tier 3 - High

Examples:

- AI use in employment, finance, healthcare, housing, education, legal, insurance, government, or safety contexts
- Biometric or sensitive-data use
- Synthetic media of identifiable people
- AI that materially informs decisions about people

- Agentic workflows that can act in production systems

Required actions:

- ☐ Complete the full AI Risk Intake and Impact Assessment
- ☐ Route to legal, privacy, security, procurement, HR, or leadership review as applicable
- ☐ Document human oversight and appeal/override path where relevant
- ☐ Document accuracy, bias, privacy, security, and monitoring controls
- ☐ Record approval conditions and review cadence
- ☐ Do not launch until the required reviewers approve

Tier 4 - Prohibited / pause

Examples:

- Uses prohibited by law, contract, or company policy
- Uses involving deception, manipulation, unlawful discrimination, or unauthorized sensitive data
- Uses that reviewers cannot explain, monitor, or control

Required actions:

- ☐ Stop the proposed use
- ☐ Preserve notes on what was proposed and why it was paused
- ☐ Route to qualified review if leadership wants to revisit it
- ☐ Do not approve through the mini-checklist

Tiering record

Field	Entry
Proposed tool / workflow	
Business owner	
Initial tier	
Reason for tier	
Reviewer	
Review date	
Required next document	
Approval conditions	
Next review date	

Reassess when any of these change

- New data categories are added
- New users, customers, markets, or jurisdictions are added
- Output becomes customer-facing or decision-related
- Tool gains integrations, autonomy, or production access
- Vendor terms, training settings, model behavior, or retention terms change

- An incident, complaint, audit finding, or regulatory change occurs

Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice and does not create an attorney-client relationship. Consult qualified counsel before relying on this decision tree for compliance decisions.